

CYBERSECURITY GOVERNANCE CASE STUDY

Healthcare Security Compliance Risk Assessment

Prepared By -

Shruti Prajapati

Computer Science & Engineering (Cybersecurity) Student

Aspiring GRC Analyst



Executive Summary

This case study presents a **Governance, Risk and Compliance (GRC) assessment** conducted for a fictional healthcare organization, **MedCare Hospital** to evaluate the organization's cybersecurity posture, regulatory obligations and operational risk exposure.

The primary objective of the assessment was to identify critical business assets, evaluate cyber threat scenarios, assess security vulnerabilities, quantify organizational risk exposure and design security control recommendations aligned with industry-recognized security and compliance frameworks.

The assessment specifically focused on the following areas:

- Critical Asset Identification and Business Impact Analysis
- Threat Landscape Assessment across healthcare infrastructure
- Vulnerability Assessment affecting confidentiality, integrity and availability
- Enterprise Risk Assessment using quantitative Likelihood × Impact methodology
- Security Control Recommendations including preventive, detective and corrective controls
- Regulatory Compliance Mapping against global privacy and cybersecurity frameworks

The assessment methodology aligns with the principles defined by:

- International Organization for Standardization ISO/IEC 27001
- HIPAA Security Rule
- PCI-DSS Payment Security Standard
- National Institute of Standards and Technology NIST Cybersecurity Framework
- GDPR Data Protection Regulation
- India DPDP Act 2023

The final objective of this assessment is to provide a structured cybersecurity governance strategy that reduces business risk, strengthens regulatory compliance, and improves organizational security maturity.

Client Environment Overview

MedCare Hospital Security Compliance Assessment

MedCare Hospital is a mid-sized healthcare organization employing approximately **120 personnel** including physicians, nursing staff, administrative employees and internal IT support teams. The organization relies heavily on digital infrastructure to support healthcare operations, patient treatment workflows, financial transactions and internal communication processes.

The hospital maintains **digitally stored patient medical records** which contain highly sensitive healthcare information including personal identification details, medical history, prescriptions, treatment records and diagnostic information. These records represent one of the organization's most critical information assets and require strong confidentiality protections due to regulatory obligations and privacy requirements.

Medical practitioners within the organization regularly use **tablet devices to access and update patient health records in real time** creating operational dependency on endpoint security, access control mechanisms and secure authentication processes. Compromise of these devices may result in unauthorized access, data manipulation or medical decision errors affecting patient safety.

The hospital provides **public guest Wi-Fi services** for patients and visitors. While this improves operational convenience and customer experience, improper network segmentation between public and internal networks may create potential attack pathways into internal hospital systems.

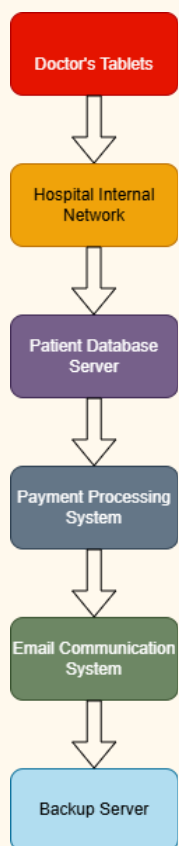
The organization's **payment processing infrastructure stores patient credit card information** for billing and healthcare payment operations. Since payment systems handle sensitive financial information, failure to properly secure payment environments may expose the organization to payment fraud, financial loss and non-compliance with payment security regulations.

Hospital staff frequently rely on **email communication for internal coordination and operational communication** making the organization vulnerable to phishing attacks, credential theft, business email compromise and other social engineering threats.

To support operational continuity, the organization maintains a **backup server physically located inside hospital premises** for storing critical healthcare and operational data. Inadequate access restrictions, privilege misuse or physical infrastructure failure may impact recovery operations and disrupt business continuity.

Given the organization's dependency on digital healthcare systems, sensitive patient information processing and regulatory compliance obligations, MedCare Hospital requires a structured **Governance, Risk and Compliance (GRC) assessment** to identify cybersecurity risks, evaluate security control weaknesses, assess regulatory exposure and design risk mitigation strategies aligned with industry security frameworks.

Architecture Diagram



Critical Asset Inventory & Business Impact Analysis

Sr. No	Critical Asset	Business Function	Security Objective (CIA)	Business Criticality	Risk if Compromised
1	Patient Medical Records	Stores patient healthcare data including diagnosis history, prescriptions, treatment records and personal identification details	Confidentiality	Critical	Unauthorized disclosure may lead to privacy violations, regulatory penalties, identity theft and loss of patient trust
2	Doctor Tablets	Enables healthcare professionals to access and update patient records in real-time during treatment operations	Integrity	High	Unauthorized access or data manipulation may result in incorrect diagnosis, medical decision errors and patient safety risks

3	Hospital Public Guest WiFi	Provides internet connectivity for hospital visitors and patients while operating within network infrastructure	Availability	Medium	Weak network controls may allow attackers to exploit wireless infrastructure and potentially move toward internal systems
4	Payment Processing System	Processes patient billing operations and stores sensitive payment card information for financial transactions	Confidentiality + Integrity	Critical	Payment fraud, financial theft, PCI-DSS non-compliance, reputational damage and direct financial losses
5	Hospital Email Communication System	Supports internal communication between healthcare staff, administrative teams and operational workflows	Integrity	High	Phishing attacks may compromise employee credentials leading to unauthorized access and operational disruption

6	Backup Server Infrastructure	Stores critical backup copies of operational data, patient records and recovery information supporting business continuity	Availability	Critical	Backup deletion, privilege misuse or hardware failure may disrupt recovery operations and affect business continuity
---	------------------------------	--	--------------	----------	--

Threat Landscape Assessment

Sr. No	Critical Asset	Threat Scenario	Threat Actor	Potential Business Impact	Attack Vector
1	Patient Medical Records	Unauthorized access resulting in patient data breach and exposure of sensitive healthcare information	External Cybercriminals / Insider Threat	Regulatory penalties, patient privacy violations, reputational damage, legal liability	Credential theft, unauthorized database access, ransomware attack
2	Doctor Tablets	Unauthorized access to medical devices leading to alteration of patient treatment records and possible incorrect diagnosis	Malicious Insider / External Attacker	Medical decision errors, patient safety risks, operational disruption	Weak authentication, stolen credentials, unsecured endpoint device
3	Hospital Public Guest WiFi Infrastructure	Compromise of guest wireless network allowing attackers to attempt lateral movement toward internal hospital systems	External Threat Actor	Network compromise, unauthorized internal system access, service disruption	Weak wireless protocols, network segmentation failure, open ports

4	Payment Processing System	Theft of payment card information resulting in fraudulent financial transactions and payment system compromise	Financial Cybercriminals	Financial loss, PCI-DSS compliance violations, reputational damage	Payment system exploitation, card data interception, insecure payment storage
5	Hospital Email Communication System	Phishing attack targeting employees resulting in credential compromise and unauthorized access to internal systems	Social Engineering Attacker	Credential theft, unauthorized access, malware infection, operational disruption	Malicious email attachments, fake login pages, business email compromise
6	Backup Server Infrastructure	Privilege escalation or unauthorized deletion of backup data leading to failed recovery operations and business continuity disruption	Malicious Insider / Privileged User Abuse	Data loss, inability to recover systems, operational downtime, recovery failure	Excessive privileges, unauthorized access, physical server compromise

Threat Assessment Methodology

Threat scenarios were identified by evaluating:

- External threat actors targeting healthcare infrastructure
- Insider threats involving privilege misuse
- Operational dependency on digital healthcare systems
- Common attack vectors affecting healthcare organizations globally

Vulnerabilities Assessment Analysis

Sr. No	Threat Scenario	Identified Control Weakness	Root Cause	Exploitation Impact	Security Domain
1	Data Breach and Misuse of Patient Health Information	Absence of Multi-Factor Authentication (MFA) and insufficient encryption controls protecting sensitive healthcare records	Weak access control implementation and inadequate data protection mechanisms	Unauthorized disclosure of patient records, privacy violations, regulatory non-compliance and reputational damage	Access Control + Data Protection
2	Unauthorized Access and Manipulation of Patient Records on Doctor Tablets	Weak password management policy, password reuse across devices, absence of automatic session timeout and inadequate endpoint security controls	Inadequate identity and access management controls for endpoint devices	Unauthorized access to medical systems, alteration of treatment records and patient safety risks	Identity & Access Management

3	WiFi Network Compromise	Use of weak wireless security protocols, improper network segmentation between guest and internal networks, unnecessary open ports and insufficient firewall configuration	Weak network security architecture and poor network segmentation design	Unauthorized network access, lateral movement into internal hospital systems and service disruption	Network Security
4	Credit Card Theft and Payment Fraud	Inadequate encryption of stored payment card information, absence of tokenization, insufficient transaction monitoring and weak payment security controls	Failure to implement secure payment data protection controls aligned with payment security standards	Financial fraud, payment data theft, compliance violations and direct financial losses	Payment Security
5	Phishing Attack and Credential Theft	Limited employee security awareness training, absence of phishing simulation exercises, weak email filtering	Human factor security weakness and insufficient security awareness program	Credential compromise, malware infection, unauthorized access and operational disruption	Security Awareness + Email Security

		controls and inadequate suspicious email reporting process			
6	Privilege Escalation Attack, Backup Data Misuse and Backup Server Failure	Excessive privilege concentration, lack of role-based access control, insufficient monitoring of backup access logs and absence of backup redundancy architecture	Weak privilege management controls and inadequate business continuity planning	Backup deletion, failed recovery operations, data loss and business continuity disruption	Privileged Access Management + Business Continuity

Vulnerability Assessment Methodology

Security vulnerabilities were identified by evaluating internal control weaknesses across critical healthcare infrastructure based on:

- Access control maturity
- Network security architecture
- Payment security controls
- Employee security awareness maturity
- Privilege management practices
- Business continuity and backup resilience controls

Enterprise Risk Matrix

$$Risk = Likelihood \times Impact$$

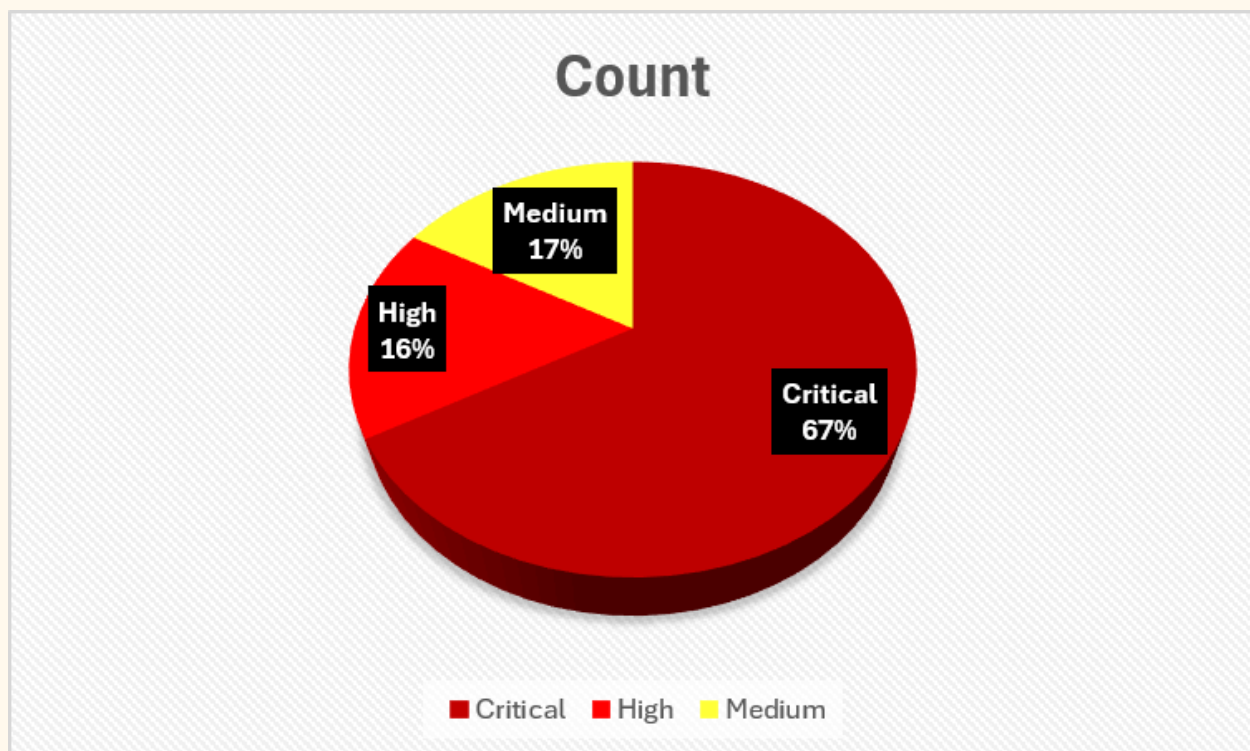
Classification : 20-25 = Critical, 15-19 = High, 8-14 = Medium, 1-7 = Low

Sr. No	Risk	Likelihood (Scale : 1 Minimum & 5 Maximum)	Impact (Scale : 1 Minimum & 5 Maximum)	Score	Priority	Rationale	Source
1	Data Breach, Misusing Patient's Health Information	4	5	20	Critical	The healthcare sector remains a high-value target for ransomware and data theft attacks. MedCare stores sensitive patient records digitally and currently lacks Multi-Factor Authentication, increasing exposure.	IBM Cost of a Data Breach Report
2	Unauthorized Access, Misdiagnosis of Diseases to a target patient	4	5	20	Critical	Doctors use tablets for accessing patient records. Weak authentication practices or stolen credentials could allow unauthorized access, potentially leading to incorrect medical decisions affecting patient safety.	National Institute of Standards and Technology NIST Access Control Guidance

3	Credit Card Theft, Payment Fraud	4	5	20	Critical	Payment infrastructure stores patient credit card information. Weak payment security controls or inadequate encryption increase exposure to financial fraud and possible violation of PCI-DSS compliance requirements.	PCI-DSS Security Standard
4	Privilege Escalation Attack, Deleting Backup Records, Misusing Backup Data, Hardware Server Failure	4	5	20	Critical	The backup server is located on-site and excessive privilege concentration allows potential misuse of backup data. Hardware failure may disrupt recovery operations and affect business continuity.	National Institute of Standards and Technology NIST CP-9 Backup Protection
5	Wifi Compromise	4	4	16	High	The hospital provides public guest WiFi access. If network segmentation is weak, attackers could attempt lateral movement into internal infrastructure through wireless exploitation or protocol weaknesses.	International Organization for Standardization ISO/IEC 27001 Network Security Controls
6	Phishing Scams	3	4	12	Medium	Hospital staff frequently depend on email communication. Phishing remains one of the most common initial access vectors, especially in	Verizon Data Breach Investigations Report (DBIR)

						organizations where employee awareness training is limited.	
--	--	--	--	--	--	---	--

PIE CHART % ANALYSIS OF RISK MATRIX



Recommended Security Controls

Sr. No	Risk	Control Recommendation	Framework Mapping	Control Type	Owner
1	Data Breach, Misuse of Patient Health Information	Implement Multi-Factor Authentication (MFA) for privileged access, Encrypt Electronic Protected Health Information (ePHI) using AES-256 encryption , Enable centralized access logging and monitoring	HIPAA Security Rule §164.312(d), National Institute of Standards and Technology NIST PR.AC-7	Preventive	IT Security Team + Compliance Officer
2	Unauthorized Access, Misdiagnosis of Diseases to Target Patient	Enforce strong password policy, Prevent password reuse using credential management policies, Configure automatic session timeout on doctor tablets, Restrict access based on user roles	National Institute of Standards and Technology NIST PR.AC-7	Preventive	IT Security Team

3	WiFi Compromise	Implement WPA3 wireless encryption , Segment guest WiFi from internal hospital network, Enable firewall protection, Close unnecessary open ports, Perform periodic network vulnerability scanning	International Organization for Standardization ISO/IEC 27001 A.8.20 (Network Security)	Preventive	Network Security Team
4	Credit Card Theft, Payment Fraud	Encrypt payment card information using AES-256 , Enable continuous transaction monitoring for anomaly detection, Use PCI-compliant payment gateway, Implement tokenization for payment card storage	PCI-DSS Requirement 3, PCI-DSS Requirement 10	Detective + Preventive	Finance Team + IT Security Team
5	Phishing Scams	Conduct monthly phishing awareness training, Perform simulated phishing campaigns, Implement email filtering and anti-phishing gateway protection, Establish suspicious email reporting process	International Organization for Standardization ISO/IEC 27001 A.6.3, NIST AT-2	Preventive	HR Team + Security Team

6	Privilege Escalation Attack, Backup Record Deletion, Misuse of Backup Data, Hardware Failure	Implement Role-Based Access Control (RBAC) , Monitor backup activity logs continuously, Restrict privileged access using least privilege principle, Create backup redundancy and disaster recovery process	International Organization for Standardization ISO/IEC 27001 A.9, NIST CP-9	Detective + Corrective	Infrastructure Team + System Administrator
---	---	--	---	------------------------------	---

Compliance Framework Mapping

Sr. No	Compliance Framework	Regulatory Requirement / Control Objective	Why Applicable to MedCare Hospital	Non-Compliance Impact
1	HIPAA (Health Insurance Portability and Accountability Act)	Protect confidentiality, integrity and availability of Electronic Protected Health Information (ePHI), implement administrative, physical and technical safeguards	Hospital stores sensitive patient healthcare information digitally which requires strong protection of medical records and patient privacy	Regulatory penalties, patient privacy violations, legal liability, reputational damage
2	International Organization for Standardization ISO/IEC 27001	Establish Information Security Management System (ISMS), implement access control, incident management and continuous security governance	Organization requires structured security governance framework to improve security maturity and manage cyber risks systematically	Weak security governance, audit findings, reduced operational security maturity
3	PIPEDA (Personal Information Protection and Electronic Documents Act)	Protect personal information collected from Canadian individuals and ensure consent-based data processing	Applicable if hospital processes healthcare information belonging to Canadian patients or international medical records	Privacy violations, legal action under Canadian privacy regulations
4	National Institute of Standards and Technology NIST Cybersecurity Framework	Implement Identify, Protect, Detect, Respond and Recover security functions for cybersecurity risk management	Hospital requires structured cybersecurity incident response planning and operational resilience against cyber attacks	Poor incident response capability, delayed recovery and higher operational disruption

5	India DPDP Act 2023	Protect personal digital data, ensure lawful processing, maintain transparency regarding data collection and allow data principal rights	Hospital processes personal data of Indian patients and must ensure secure data handling and privacy rights compliance	Regulatory penalties, privacy complaints, legal liability under Indian data protection law
6	GDPR (General Data Protection Regulation)	Protect personal data of EU residents, ensure lawful data processing, data minimization and privacy rights protection	Applicable if hospital stores healthcare records belonging to European Union residents	Financial penalties up to 4% of global annual revenue, reputational damage and regulatory investigation

Compliance Assessment Methodology

Compliance obligations were mapped by evaluating regulatory requirements applicable to healthcare organizations handling sensitive healthcare data, payment information, personal digital records and cross-border data processing obligations.

Residual Risk Assessment & Control

Sr. No	Risk	Initial Risk Score	Security Controls Implemented	Residual Risk Score	Residual Risk Rating	Justification
1	Data Breach and Misuse of Patient Health Information	20	Multi-Factor Authentication, AES-256 encryption, centralized access monitoring and audit logging	8	Medium	Strong access controls and encryption significantly reduce unauthorized access probability, although insider threat risk remains
2	Unauthorized Access and Manipulation of Patient Records	20	Strong password policy, automatic session timeout, role-based access restrictions and endpoint security controls	7	Medium	Improved authentication and session management reduce unauthorized access risk, but device theft remains possible
3	Credit Card Theft and Payment Fraud	20	Payment data encryption, PCI-DSS compliant payment gateway, transaction monitoring and payment tokenization	6	Medium	Payment security controls significantly reduce financial fraud risk, though external payment attacks may still occur

4	Privilege Escalation Attack and Backup Data Misuse	20	Role-Based Access Control (RBAC), least privilege enforcement, backup monitoring and disaster recovery planning	7	Medium	Access restrictions reduce privilege abuse risk, however insider misuse cannot be fully eliminated
5	WiFi Network Compromise	16	WPA3 encryption, network segmentation, firewall implementation and periodic vulnerability scanning	5	Low	Network security controls reduce attack pathways, making compromise significantly more difficult
6	Phishing Attack and Credential Theft	12	Employee awareness training, phishing simulation exercises, email filtering and suspicious email reporting process	9	Medium	Human behavior remains unpredictable, therefore phishing risk can be reduced but never completely eliminated

Residual Score	Rating
1–5	Low
6–10	Medium
11–15	High
16–25	Critical

Final Recommendations

Immediate Actions :

- Implement MFA (For Example - Username & Password, OTP Verification, Biometric Authentication or Using an Authenticator App)
- Encrypt ePHI (Using Encrypting Algorithms like AES-256, TLS 1.3 for data in transit, etc.)
- Deploy RBAC (Using Principle of Least Privilege & Separation of Duties)
- Conduct enterprise phishing simulation exercises using appropriate tools
- Analyzing the Following -
 - i. Incident Reporting Rate (IRR): The percentage of users who clicked the "Report Phish" button.
 - ii. Time-to-Report (TTR): The exact number of minutes it takes from deployment to the first user report.
 - iii. Data Submission Rate: The critical count of employees who actually entered credentials or sensitive text into the spoofed landing page
- Secure Payment Infrastructure (Implementing End-to-end Encryption, Tokenization, Deploy Machine Learning tools for real time fraud detection)
- Improve backup redundancy (Adopt the 3-2-1 backup rule by keeping 3 total copies of data, across 2 different media types with 1 copy stored securely off-site)

Final Security Assessment Conclusion

The Governance, Risk and Compliance (GRC) assessment conducted for MedCare Hospital identified multiple critical cybersecurity risks affecting healthcare data protection, payment security, access management, network security, employee awareness and business continuity operations.

The assessment identified several high-risk areas requiring immediate remediation, particularly patient data protection, payment infrastructure security, phishing attack exposure and privileged access management weaknesses.

Implementation of recommended preventive, detective and corrective controls significantly reduces organizational cyber risk exposure while improving alignment with healthcare security and privacy regulations including HIPAA, PCI-DSS, ISO/IEC 27001, GDPR, NIST Cybersecurity Framework and India's DPDP Act 2023.

Overall, the assessment demonstrates that a structured security governance strategy combined with continuous compliance monitoring can significantly improve organizational security maturity and reduce long-term operational and regulatory risk exposure.